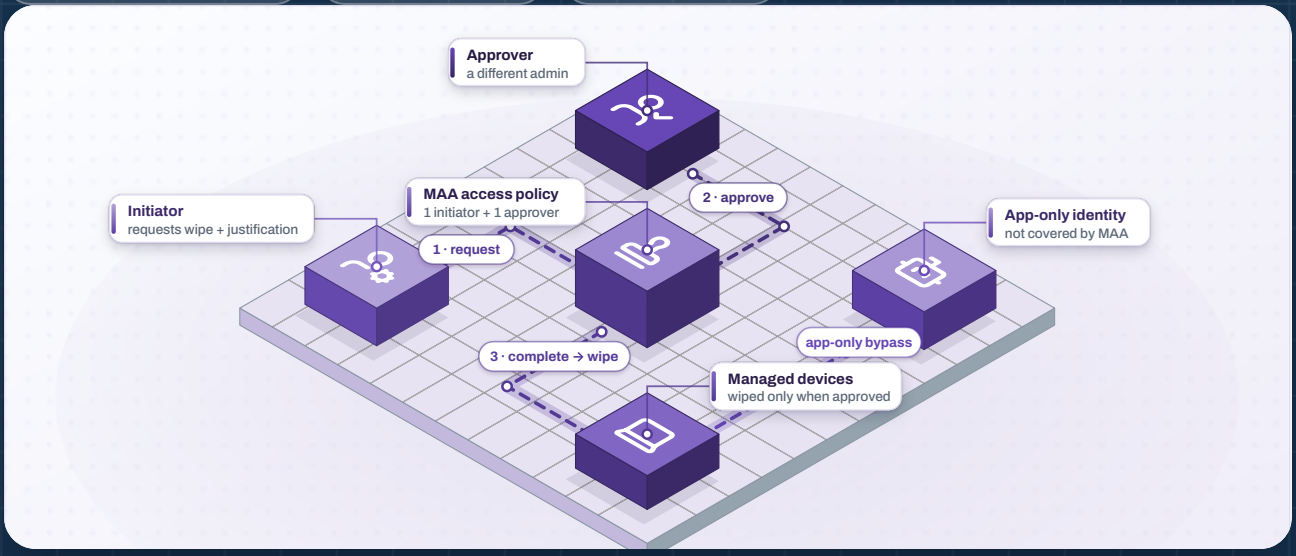
STANDARD OPERATING PROCEDURE · FIELD GUIDE SERIES

SOP-EM-003

Enforcing Multi Admin Approval for Intune Device Wipe, Retire and Delete

A two-person rule for destructive device actions, configured in the Intune admin center or with Graph PowerShell (beta), with a request-notification flow and an audit of the app-permission bypass.

Endpoint Management | Microsoft Intune | Access Control



DOCUMENT ID	SOP-EM-003
VERSION	2.0
EFFECTIVE	October 2026
AUDIENCE	Intune administrators, cloud security engineers, IT auditors
AUTHOR	Richmond Dieujuste, Principal Consultant

Rich Dieu IT Solutions LLC · richdieu.com

Sanitized reference edition — client identifiers removed

Contents

1. Concepts You Need First 3

1.1 Separation of duties and dual authorization 4

1.2 The control boundary 4

1.3 Choosing a method 6

2. Access, Prerequisites and Planning 7

2.1 Level of access required 7

2.2 Prerequisites checklist 8

2.3 Decisions to make up front 8

3. Method A · Intune and Entra Admin Centers 10

3.1 Operating procedure: performing a protected wipe 13

4. Method B · Microsoft Graph PowerShell Template (Beta) 14

5. Methods C and D · Compensating Controls 17

5.1 Method C · Approver notification flow 17

5.2 Method D · Audit the application-permission bypass 18

6. Verification, Evidence and Troubleshooting 20

6.1 Verification tests 20

6.2 Rollback 20

6.3 Framework mapping 20

6.4 Troubleshooting 21

7. Summary, Glossary and Review 23

7.1 Chapter summary 23

7.2 Glossary 23

LEARNING OBJECTIVES

After working through this procedure you will be able to:

- Explain the four-eyes principle, separation of duties and where Multi Admin Approval enforces them.
- Describe the MAA control boundary, including the application-permission bypass.
- Create the approver group, its Intune role assignment and the wipe, retire and delete policies.

- Automate the setup and request reporting with Microsoft Graph PowerShell (beta endpoints).
- Build an approver notification flow and audit apps that hold privileged Intune permissions.
- Map the control to NIST SP 800-53, ISO/IEC 27001 and CIS Controls with the right evidence.

TIME	DIFFICULTY	MINIMUM ROLE	RISK
≈ 45 min + second-admin approval	Intermediate	Intune Administrator or custom MAA role; Groups Administrator	Medium: misconfiguration can block urgent wipes

CHAPTER 1

Concepts You Need First

A single Intune administrator can erase every managed laptop and phone in an organization with a few clicks. Usually that power is used to protect data on a lost device. But the same click, made by mistake, by a disgruntled insider or by an attacker who has phished an admin account, can take a whole workforce offline. Attackers know this: wiping managed devices through a compromised management console is a documented destructive technique. **Multi Admin Approval (MAA)** is Intune's built-in way to make sure that no single person can perform such an action alone.

KEY CONCEPT · TWO KEYS FOR THE VAULT

Bank vaults and missile silos use the **two-person rule**: two different people must each turn a key. Neither can act alone, and each checks the other. Security people call this the **four-eyes principle**. MAA applies it to Intune: one administrator requests a wipe and explains why, and a *different* administrator must approve it before it can run.

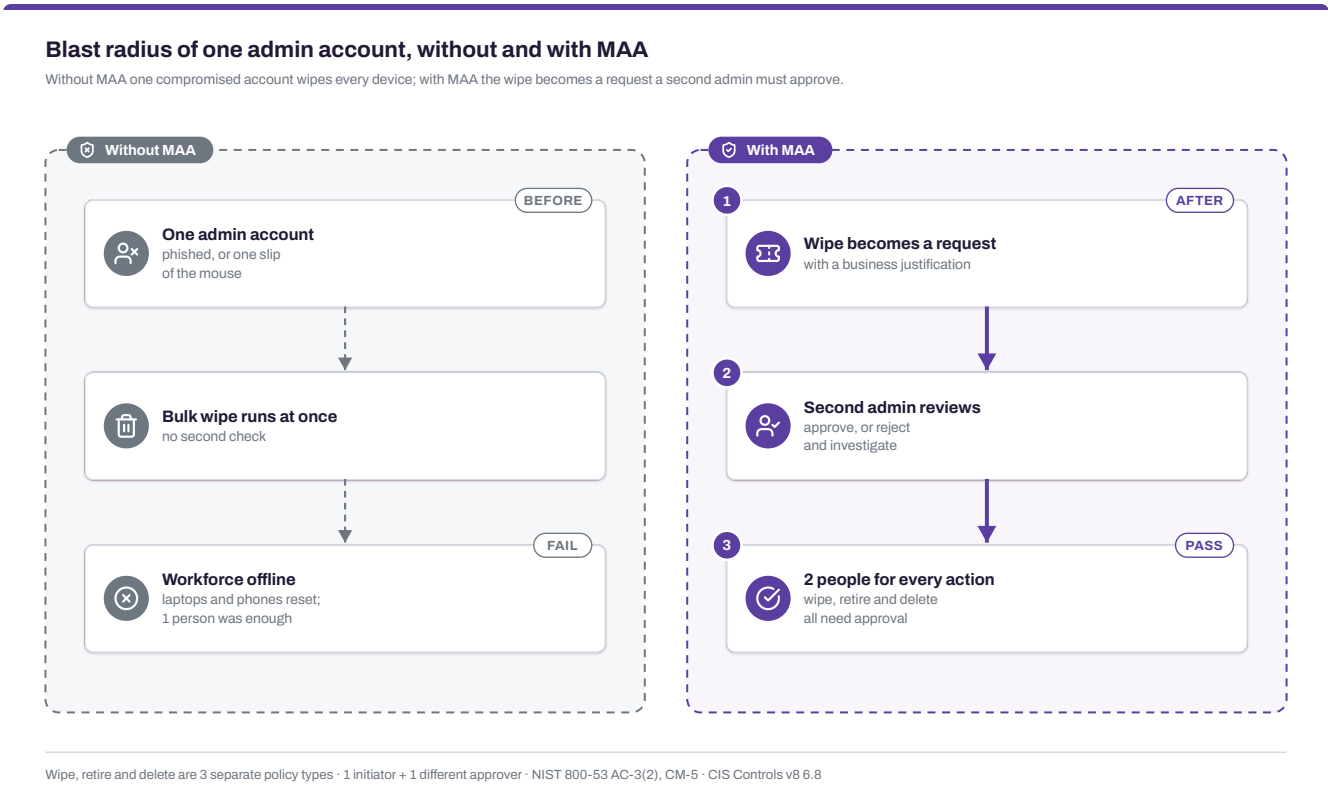


Figure 1. MAA does not make a phished admin account harmless; it shrinks what that one account can do alone from wiping the fleet to filing a request.

1.1 Separation of duties and dual authorization

Two related controls are at work:

- **Separation of duties** splits a sensitive task so that the person who *asks* is not the person who *authorizes*. In MAA the initiator can never approve their own request, even if they are a member of the approver group or a Global Administrator.
- **Dual authorization** requires two authorized individuals for a specific privileged action. Here the action is a device wipe (and, when extended, retire and delete).

MAA implements *exactly one* approver in addition to the initiator. It cannot require two or three approvers, so the approver group should be small, trusted and reachable.

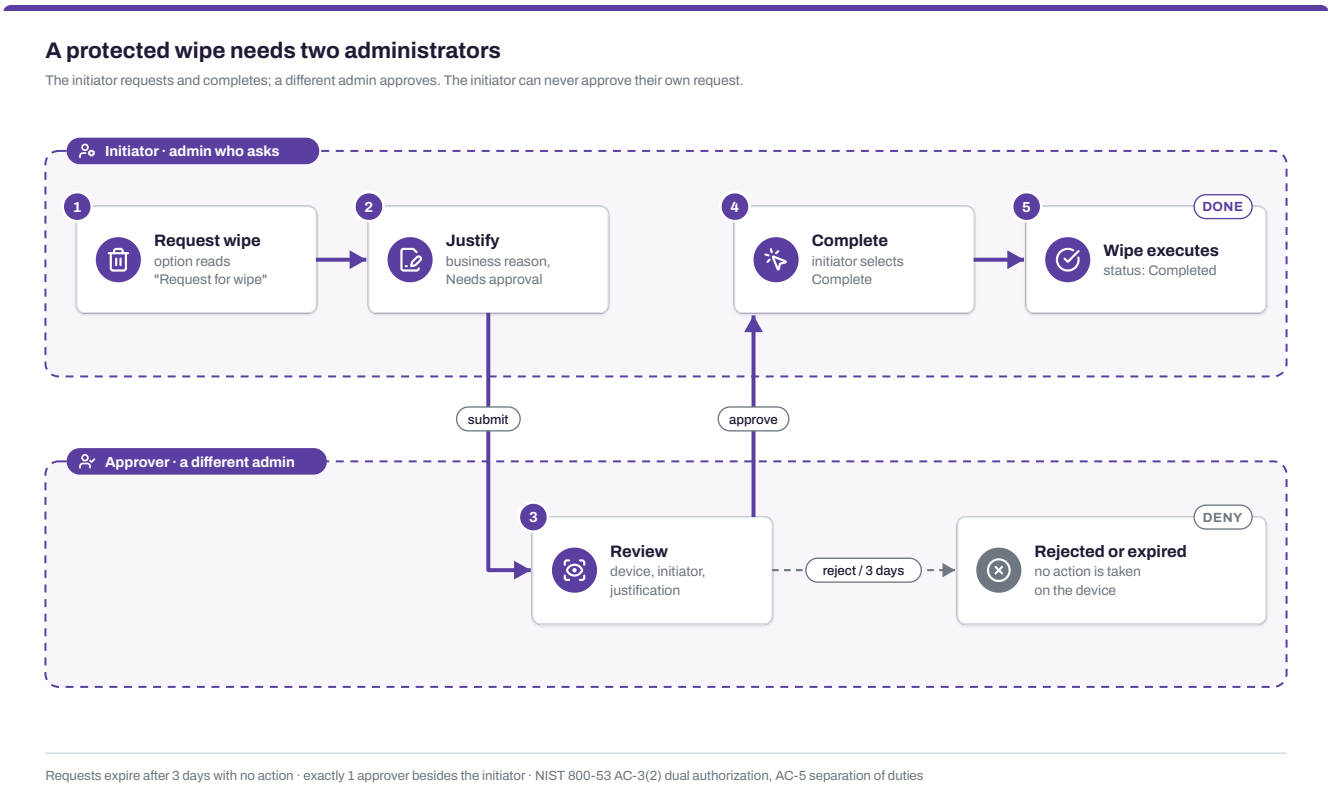


Figure 2. Nothing happens to the device until the initiator completes an approved request, so a rejected or expired request is always safe.

1.2 The control boundary

MAA is a strong control, but it is not an absolute lock. It is enforced for actions taken by a **user identity**: the Intune admin center, Microsoft Graph called with *delegated* permissions, and PowerShell with interactive sign-in. It is **not** enforced for an app registration that calls Graph with *application* permissions (the client-credentials flow), because no human is behind the call to act as initiator. Such an app holding `DeviceManagementManagedDevices.PrivilegedOperations.All` can wipe devices with no approval.

Limitation	Consequence and compensating action
Application-permission bypass	Primary residual risk. Restrict and quarterly review apps with privileged Intune Graph permissions (Method D); govern them with Conditional Access for workload identities.
One policy per action	Wipe, retire and delete are separate policy types. Protecting only wipe leaves retire and delete open. Create all three.
Local reset	A factory reset performed physically on the device is outside Intune and outside MAA.
No native notifications	Approvers are not alerted and requests expire after three days. Build a notification flow (Method C).

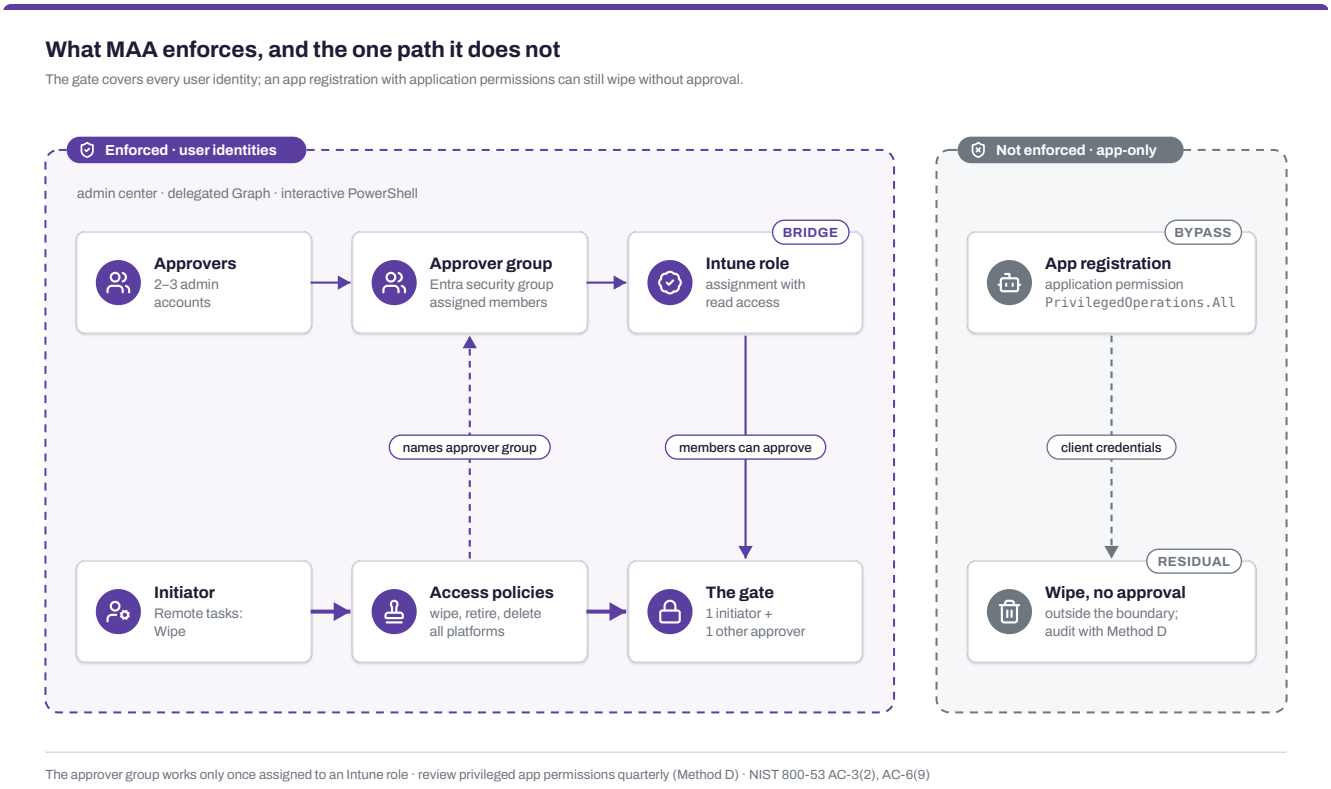


Figure 3. The approver group does nothing until it is assigned to an Intune role, and app-only identities sit outside the gate entirely, which is why Method D exists.

WHY IT MATTERS · BRIDGE STEP

A group named as approver in a policy does nothing on its own. Intune only honors approvals from members of groups that are *assigned to an Intune role*. Missing this step is the most common silent failure: approvers simply cannot approve.

1.3 Choosing a method

A · Intune admin center

Create the group, role assignment and three access policies; activate with a second admin.

BEST FOR: FIRST ROLLOUT, LEARNING

B · Graph PowerShell (beta)

Template that creates the group, role assignment and policies, and reports pending requests.

BEST FOR: MULTI-TENANT, REPEATABILITY

C · Notification flow

Logic App / Power Automate polling Graph, or an Azure Monitor alert on Intune audit logs.

BEST FOR: EVERY DEPLOYMENT

D · Bypass audit

Script listing apps that hold privileged Intune application permissions.

BEST FOR: QUARTERLY COMPENSATING CONTROL

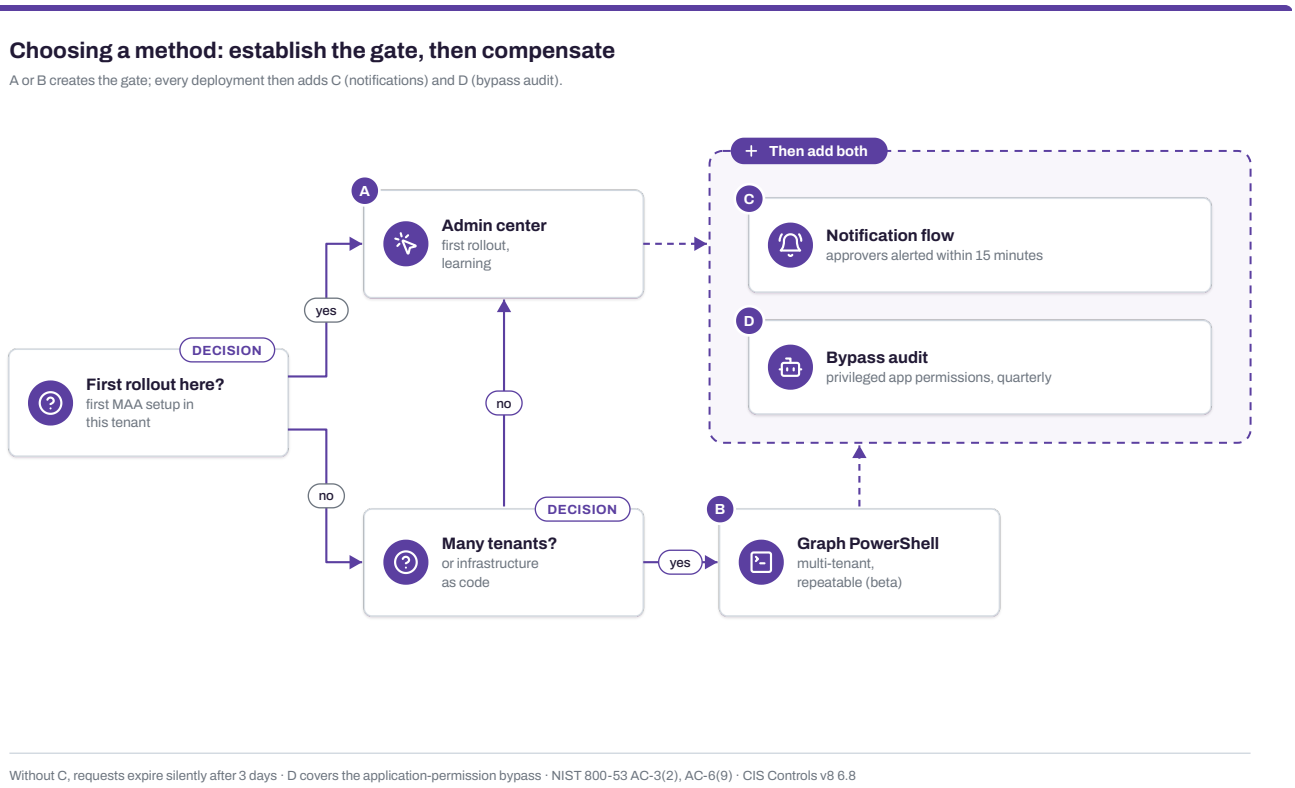


Figure 4. A or B only establishes the gate; the notification flow and the bypass audit are what keep it usable and honest, so every deployment adds both.

CHAPTER 2

Access, Prerequisites and Planning

2.1 Level of access required

MAA separates three roles: the **access policy manager** who configures the gate, the **initiator** who requests a destructive action and the **approver** who authorizes it. Ideally these are different people; at minimum the initiator and approver of any one request always are.

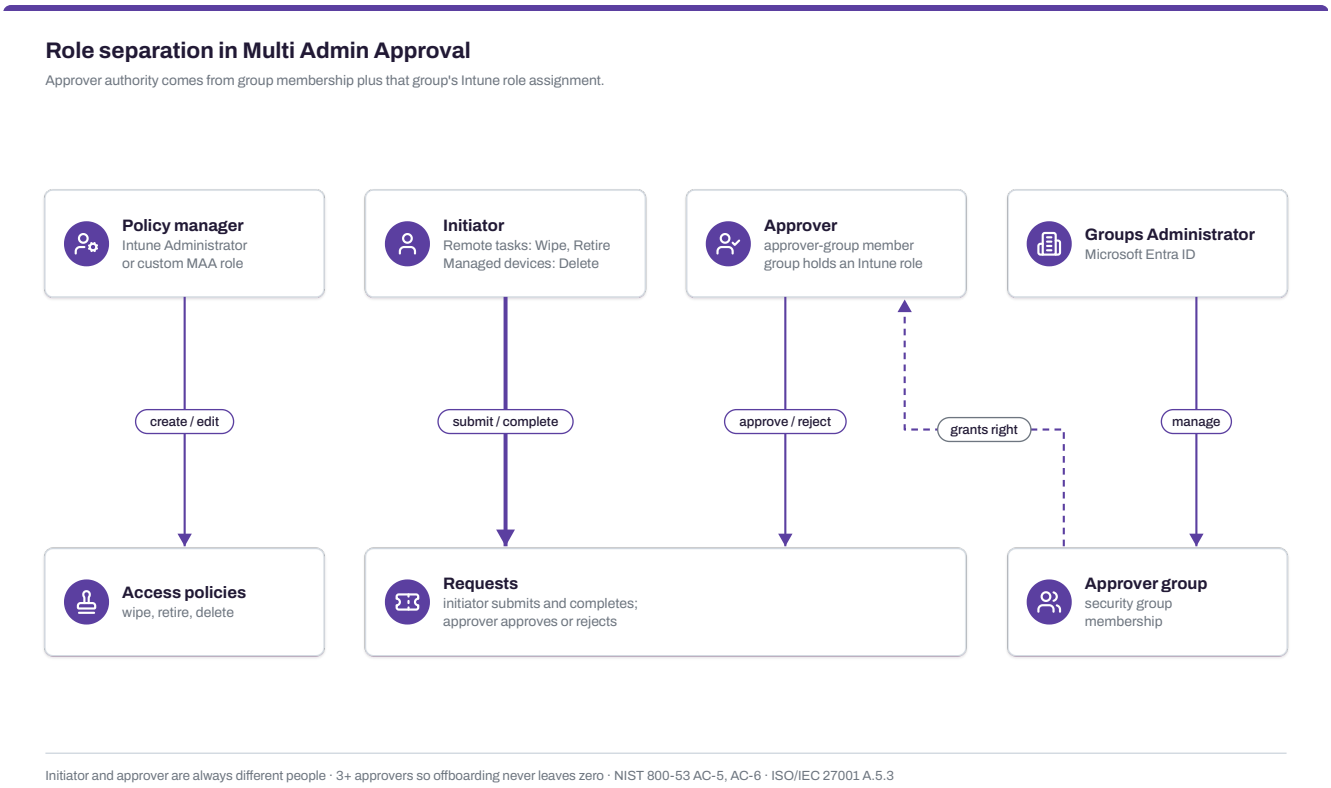


Figure 5. Being in the approver group is not enough on its own: approval authority needs the membership plus the group's Intune role assignment.

Task	Least-privilege role / permission	Notes
Create the approver security group	Groups Administrator (Entra); Graph `Group.ReadWrite.All`	Security group, assigned membership, not role-assignable.
Assign the group to an Intune role	Intune Role Administrator (Intune) or Intune Administrator; Graph `DeviceManagementRBAC.ReadWrite.All`	Use a least-privilege role such as Read Only Operator or a custom read role.

Create / edit access policies	Custom Intune role with the *Multi Admin Approval* access-policy permissions, or Intune Administrator	Every change is itself an approval request.
Initiate wipe / retire / delete	Intune role with *Remote tasks › Wipe, Retire* and *Managed devices › Delete* (e.g. Help Desk Operator or custom)	The initiator also selects `Complete`.
Approve a request	Member of the approver group; group assigned to an Intune role	Cannot approve own request.
Build the notification flow	Logic App Contributor on the resource group; Privileged Role Administrator to grant the managed identity a Graph app role	Grant *read-only* app permissions.
Audit privileged apps	Global Reader or Security Reader (Entra); Graph `Application.Read.All`	Read-only.

GOOD PRACTICE · JUST-IN-TIME PRIVILEGE

Combine MAA with Privileged Identity Management: make Intune Administrator *eligible*, and make the approver group a PIM for Groups target so approval authority itself is time-bound. An attacker then needs two compromised accounts *and* two activations.

2.2 Prerequisites checklist

- [ ] Microsoft Intune Plan 1 licensing for participating administrators (included in Microsoft 365 E3/E5, EMS E3/E5 and Business Premium).
- [ ] At least two distinct administrator accounts in the approver group; three or more so that leave or offboarding never leaves zero approvers.
- [ ] A dedicated Microsoft Entra **security** group. Distribution lists, Microsoft 365 groups and mail-enabled security groups are not supported and fail silently.
- [ ] A documented decision on who holds approval authority and how emergency (out-of-hours) wipes are approved.
- [ ] An approved change record, for example `CHG0012345`.

2.3 Decisions to make up front

Decision	Guidance
Scope of actions	Wipe, retire *and* delete. Consider also gating scripts, roles and the MAA policy type itself.

Platform scope	All platforms, so no operating system is left ungated.
Approver pool	Senior admins across time zones; never the whole help desk.
Emergency path	A lost-device wipe still needs a second admin: publish an on-call approver rota.

CHAPTER 3

Method A · Intune and Entra Admin Centers

STEP 1 Create the approver security group

1. In the Microsoft Entra admin center go to **Entra ID › Groups › New group**.
2. Set *Group type* to **Security**. Any other type fails as an approver group.
3. Name it `SG-Intune-MAA-Device-Wipe-Approvers` with a clear description.
4. Leave *Microsoft Entra roles can be assigned to the group* at **No** and *Membership type* at **Assigned**.
5. Add at least two administrators as **Members** (owners are not approvers) and select **Create**.

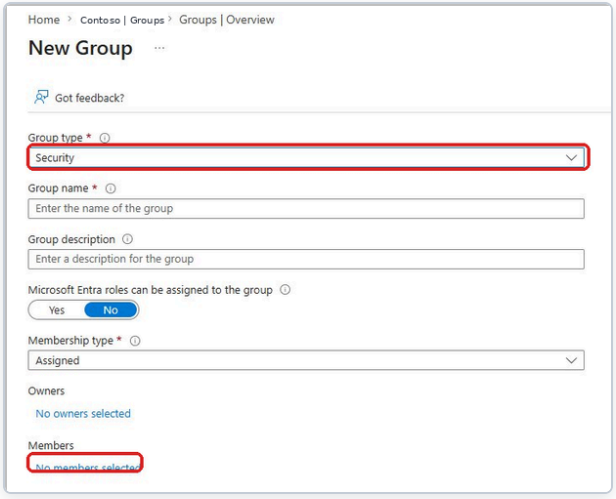


Figure 6. New group blade: Group type Security and the Members link (highlighted).

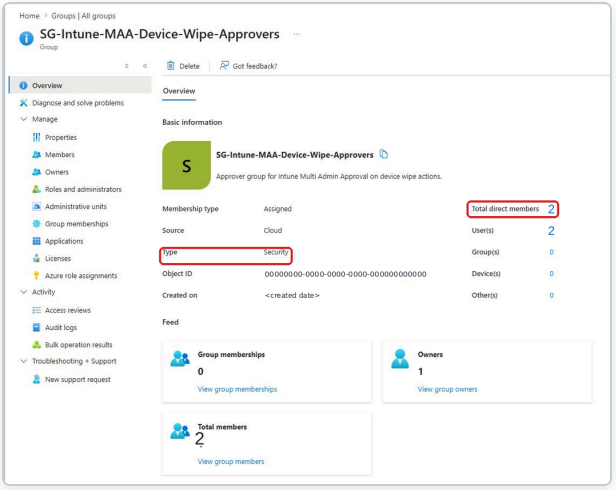


Figure 7. Required end state: Type Security with two direct members. Object ID removed.

STEP 2 Assign the approver group to an Intune role (bridge step)

1. In the Intune admin center go to **Tenant administration › Roles › All roles**.
2. Select a role with read access to devices, preferably a least-privilege custom role (or the built-in *Read Only Operator*).
3. Open **Assignments › Assign**, name the assignment, add `SG-Intune-MAA-Device-Wipe-Approvers` as the **member group**, set scope to all devices and users (or the

scope the approvers must review), and create it.

WATCH OUT · SILENT FAILURE

If this step is skipped, members cannot approve requests and Entra may periodically clean them out of the group. Verify by signing in as an approver and opening **Multi Admin Approval › Received requests**.

STEP 3 Create the Device wipe access policy

1. Go to **Tenant administration › Multi Admin Approval › Access policies › Create**.
2. **Basics**: name `MAA - Device Wipe`, description naming the approver group; *Policy type* **Device wipe**. Confirm the platform resolves to **All platforms**.
3. **Approvers**: **Add groups** › the approver group.
4. **Review + submit for approval**: enter a business justification that cites the change record and submit.

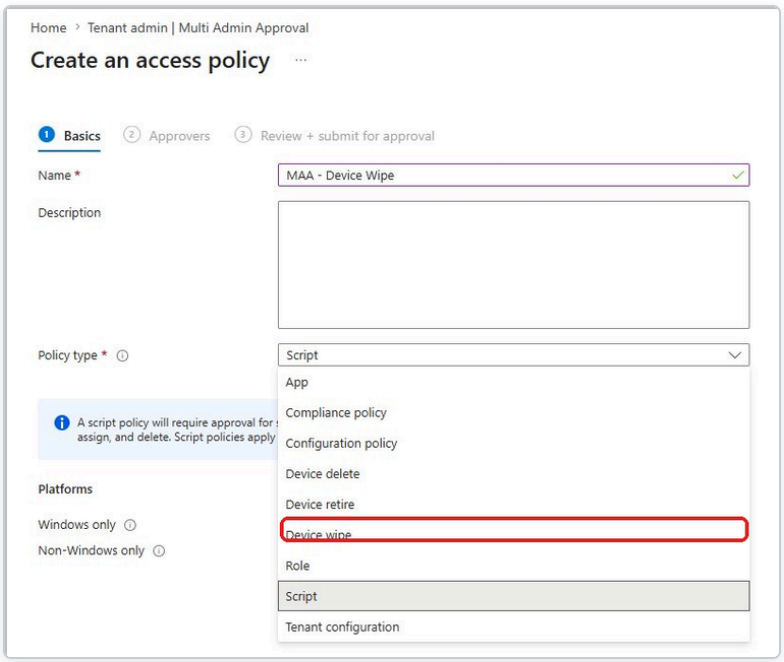


Figure 8. Policy type list. Device delete, Device retire and Device wipe are separate types; this policy selects **Device wipe**.

STEP 4 Activate the policy (dual-admin handshake)

Creating an access policy is itself a protected change, so the gate protects its own configuration.

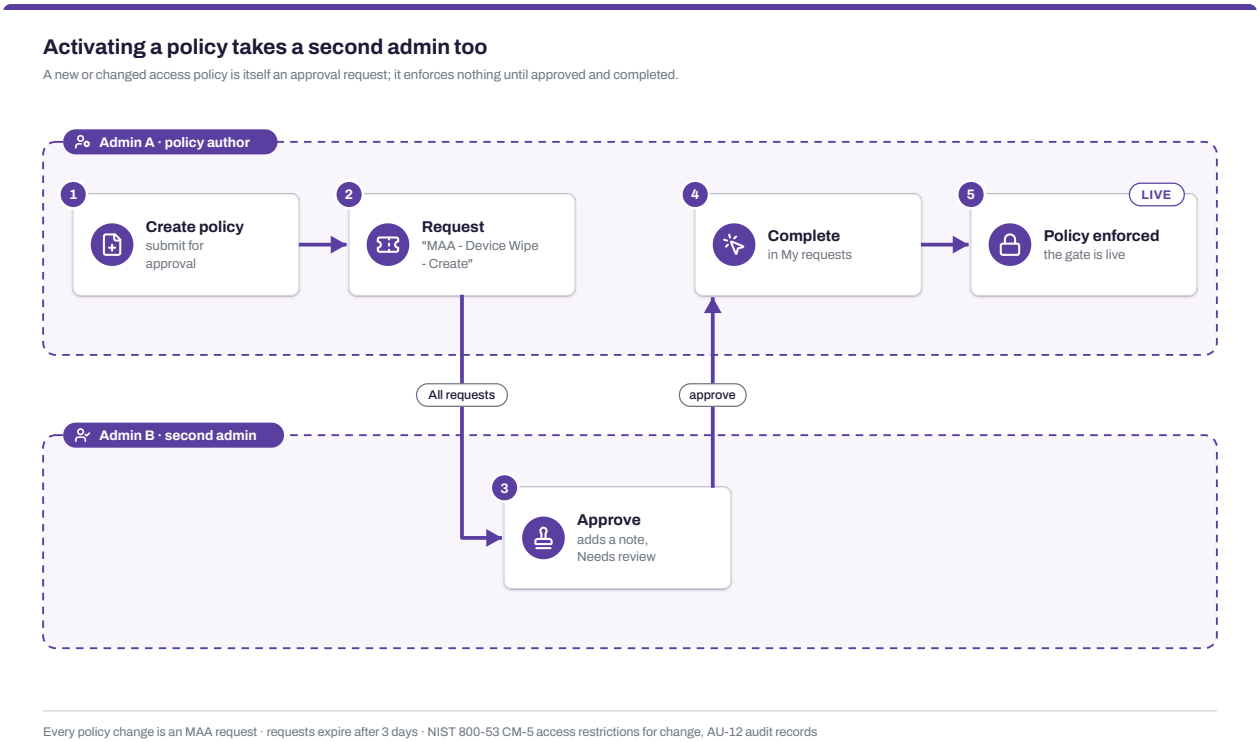


Figure 9. MAA protects its own configuration, so even the first policy needs a second administrator before it enforces anything.

1. A *different* administrator signs in, opens **Multi Admin Approval › All requests**, selects the pending *MAA - Device Wipe - Create* request, adds a note and selects **Approve**.
2. The creator returns to **My requests**, opens the request and selects **Complete request**. Only now is the gate live.

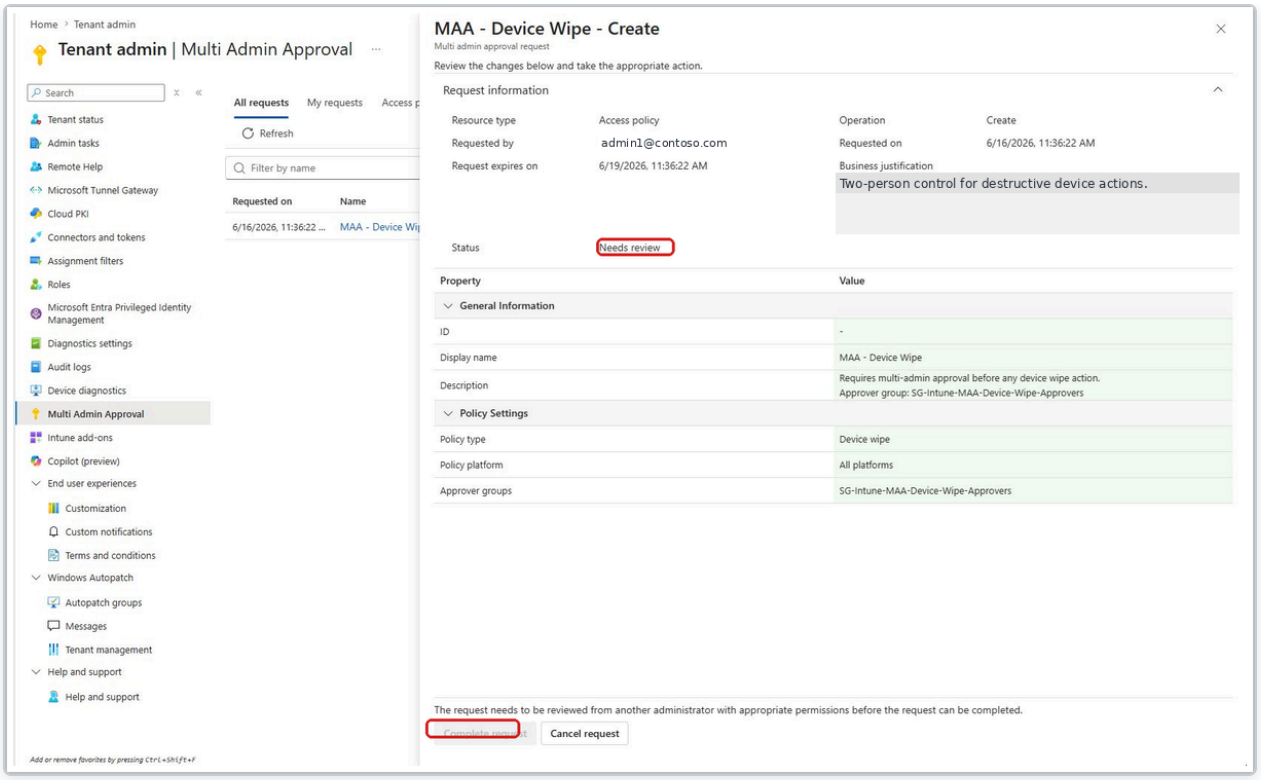


Figure 10. The policy-creation request in *Needs review*. `Complete request` stays disabled until another administrator approves. Requester and justification replaced with placeholders.

STEP 5 **Extend to retire and delete**

Repeat Steps 3 and 4 twice, choosing **Device retire** (`MAA - Device Retire`) and **Device delete** (`MAA - Device Delete`), both pointing to the same approver group. Until both are live, a single administrator can still retire or delete devices.

3.1 Operating procedure: performing a protected wipe

1. The initiator opens the device in Intune and selects **Wipe**. With the gate active the dialog reads *Request for wipe*.
2. The initiator enters a business justification (ticket number, device owner, reason) and submits. Status: *Needs approval*, tracked under **My requests**.
3. An approver opens the request under **All requests** or **Received requests**, checks the device, the requester and the justification against the ticket, adds a note and selects **Approve** or **Reject**.
4. After approval the initiator selects **Complete**; the wipe is sent and the status becomes *Completed*.

CHAPTER 4

Method B · Microsoft Graph PowerShell Template (Beta)

The template creates the approver group and its members (Graph v1.0), assigns the group to an Intune role and creates the three access policies (Graph **beta**), then lists requests waiting for a second administrator. Policy creation through Graph enters the same approval workflow as the portal: the script cannot, and must not be able to, approve its own change.

CAUTION · BETA ENDPOINTS

`operationApprovalPolicies`, `operationApprovalRequests` and Intune role assignment scope types are Microsoft Graph **beta** resources. Property names and enum values can change without notice and beta is not supported for production automation. Before running, create one policy in the portal and read it back with `GET .../beta/deviceManagement/operationApprovalPolicies` to confirm the current values for `policyType` and `policyPlatform` in your tenant.

SET-INTUNEMAAGATE.PS1 · BASE TEMPLATE POWERSHELL

```powershell
<#
.SYNOPSIS  Configure Intune Multi Admin Approval for device wipe / retire / delete.
           Stage 1 approver group (v1.0) - Stage 2 Intune role assignment (beta)
           Stage 3 access policies (beta, enter approval) - Stage 4 pending-request report (beta)
.NOTES     Modules: Microsoft.Graph.Authentication, Microsoft.Graph.Groups, Microsoft.Graph.Users
           Roles  : Groups Administrator + Intune Administrator (or custom MAA + role-admin role)
           Scopes : verify DeviceManagementRBAC.* against the current Graph beta reference.
#>
[CmdletBinding(SupportsShouldProcess)]
param(
  [Parameter(Mandatory)] [string[]] $ApproverUpns,        # at least 2 distinct admins
  [Parameter(Mandatory)] [string]   $ChangeRef,           # e.g. CHG0012345
  [string]   $GroupName      = 'SG-Intune-MAA-Device-Wipe-Approvers',
  [string]   $IntuneRoleName = 'Read Only Operator',      # or your least-privilege custom role
  [string[]] $PolicyTypes    = @('deviceWipe', 'deviceRetire', 'deviceDelete'),
  [string]   $PolicyPlatform = 'notApplicable',           # 'All platforms' - CONFIRM via GET first
  [string]   $EvidencePath   = ".\$ChangeRef-maa-evidence.json"
)
$ErrorActionPreference = 'Stop'
if (@($ApproverUpns | Select-Object -Unique).Count -lt 2) { throw 'MAA needs at least 2 approvers.' }
$beta = 'https://graph.microsoft.com/beta'; $json = 'application/json'
Connect-MgGraph -NoWelcome -Scopes 'Group.ReadWrite.All', 'User.Read.All',
                                   'DeviceManagementRBAC.ReadWrite.All'
$ev = [ordered]@{ ChangeRef = $ChangeRef; Operator = (Get-MgContext).Account
                  TimeUtc = (Get-Date).ToUniversalTime().ToString('o') }

# ---- Stage 1: approver security group (assigned, not role-assignable) -------
$grp = Get-MgGroup -Filter "displayName eq '$GroupName'" | Select-Object -First 1
if (-not $grp -and $PSCmdlet.ShouldProcess($GroupName, 'Create security group')) {
  $grp = New-MgGroup -DisplayName $GroupName -SecurityEnabled -MailEnabled:$false `
           -MailNickname ($GroupName.ToLower()) -IsAssignableToRole:$false `
           -Description "Approvers for Intune MAA device wipe/retire/delete ($ChangeRef)"
}
```

```
if ($grp) {
  $current = (Get-MgGroupMember -GroupId $grp.Id -All).Id
  foreach ($upn in $ApproverUpns) {
    $u = Get-MgUser -UserId $upn
    if ($u.Id -notin $current -and $PSCmdlet.ShouldProcess($upn, "Add to $GroupName")) {
      New-MgGroupMember -GroupId $grp.Id -DirectoryObjectId $u.Id
    }
  }
  $ev.GroupId = $grp.Id; $ev.Approvers = $ApproverUpns
}

# ---- Stage 2: bridge step - assign the group to an Intune role (beta) ------
$roles = (Invoke-MgGraphRequest GET "$beta/deviceManagement/roleDefinitions").value
$rd = $roles | Where-Object displayName -eq $IntuneRoleName | Select-Object -First 1
if (-not $rd) { throw "Intune role '$IntuneRoleName' not found." }
if ($grp -and $PSCmdlet.ShouldProcess($IntuneRoleName, "Assign $GroupName")) {
  $body = @{
    displayName = "MAA approvers - $GroupName"; description = "Bridge step for MAA ($ChangeRef)"
    members = @($grp.Id); resourceScopes = @(); scopeType = 'allDevicesAndLicensedUsers'
    'roleDefinition@odata.bind' = "$beta/deviceManagement/roleDefinitions('$($rd.id)')"
  } | ConvertTo-Json -Depth 4
  $ra = Invoke-MgGraphRequest POST "$beta/deviceManagement/roleAssignments" -Body $body -ContentType
$json
  $ev.RoleAssignmentId = $ra.id
}

# ---- Stage 3: access policies (each creation becomes an approval request) ---
$existing = (Invoke-MgGraphRequest GET "$beta/deviceManagement/operationApprovalPolicies").value
$labels = @{ deviceWipe = 'Device Wipe'; deviceRetire = 'Device Retire'; deviceDelete = 'Device Delete' }
$ev.Policies = foreach ($t in $PolicyTypes) {
  $name = "MAA - $($labels[$t])"
  if ($existing | Where-Object { $_.policyType -eq $t }) { "$name : already exists"; continue }
  if ($grp -and $PSCmdlet.ShouldProcess($name, 'Create access policy (submits for approval)')) {
    $body = @{ displayName = $name; policyType = $t; policyPlatform = $PolicyPlatform
               description = "Two-person rule. Approver group: $GroupName. $ChangeRef"
               approverGroupIds = @($grp.Id) } | ConvertTo-Json
    Invoke-MgGraphRequest POST "$beta/deviceManagement/operationApprovalPolicies" `
      -Body $body -ContentType $json | Out-Null
    "$name : submitted"
  }
}

# ---- Stage 4: requests waiting for a SECOND administrator -------------------
$reqs = (Invoke-MgGraphRequest GET "$beta/deviceManagement/operationApprovalRequests").value
$ev.Pending = $reqs | Where-Object status -eq 'needsApproval' | ForEach-Object {
  [pscustomobject]@{ Id = $_.id; Requested = $_.requestDateTime; Expires = $_.expirationDateTime
                     Requestor = $_.requestor.user.displayName; Justification = $_.requestJustification }
}
$ev | ConvertTo-Json -Depth 6 | Out-File $EvidencePath -Encoding utf8
$ev.Pending | Format-Table -AutoSize
Write-Warning 'A DIFFERENT admin must approve; then select Complete in My requests.'
```

EXAMPLE · RUNNING THE TEMPLATE

INVOCATION POWERSHELL

```powershell
.\Set-IntuneMaaGate.ps1 -ChangeRef 'CHG0012345' -IntuneRoleName 'MAA Approver (read)' `
  -ApproverUpns 'admin1@contoso.com', 'admin2@contoso.com', 'admin3@contoso.com' `
  -WhatIf                                                  # preview, then run without -WhatIf
```

KEY CONCEPT · WHY THE SCRIPT CANNOT FINISH THE JOB

If a script could create *and* activate an MAA policy, so could an attacker with the same token. Approval must come from a different human identity, and completion from the original requester. Automation can prepare and report; it cannot replace the second pair of eyes.

CHAPTER 5

Methods C and D · Compensating Controls

5.1 Method C · Approver notification flow

Intune does not notify approvers, and a request silently expires after three days. In a regulated environment treat notification as a required part of the control, not an enhancement. Two designs work:

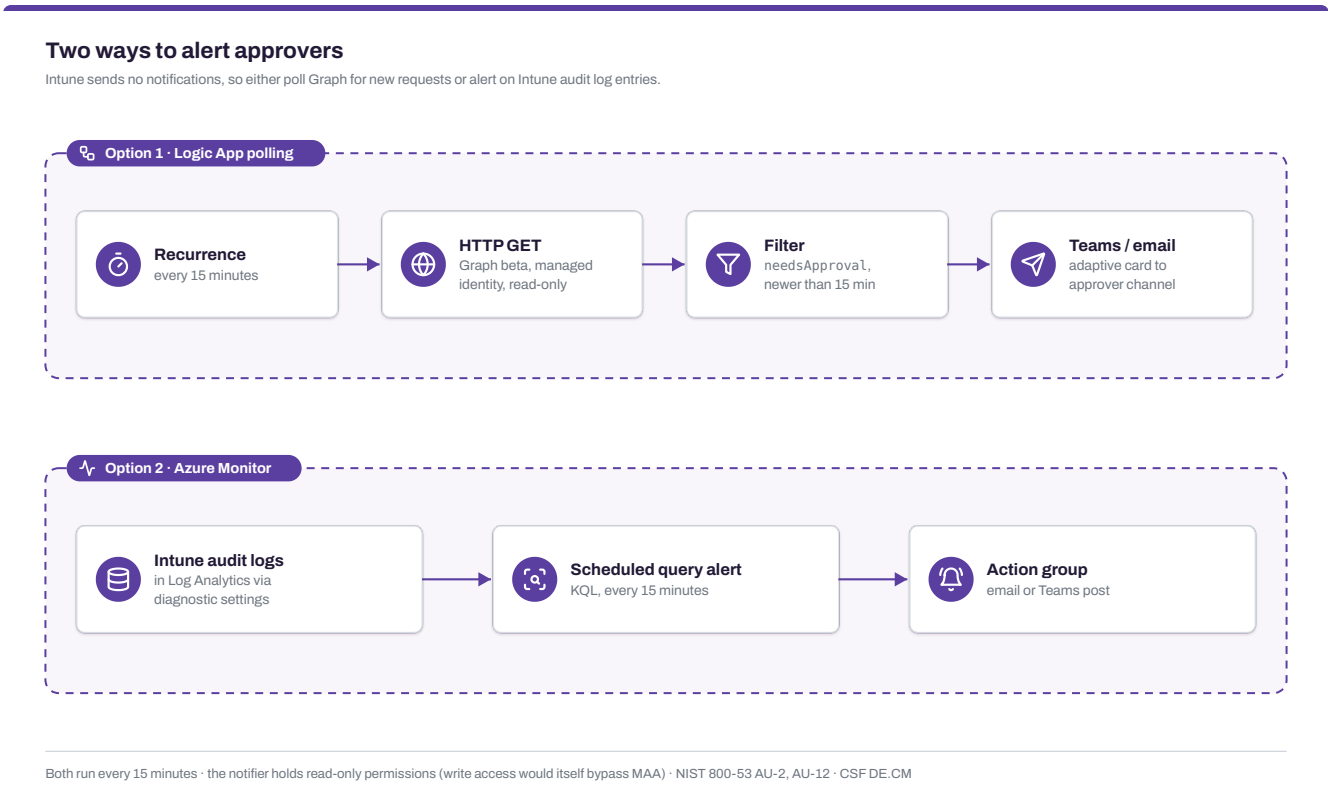


Figure 11. Pick polling when you want per-request detail in Teams, or the audit-log alert when Intune logs already flow to Log Analytics; either way approvers must hear about requests within the 3-day expiry.

Option 1 · Logic App or Power Automate polling Graph

1. Create a Consumption Logic App with a **system-assigned managed identity**.
2. Grant the identity a *read-only* Graph application role (script below). Never give the notifier a write permission: it would itself become an MAA bypass.
3. Trigger: `Recurrence` every 15 minutes. Action: `HTTP` GET `https://graph.microsoft.com/beta/deviceManagement/operationApprovalRequests`, authentication *Managed identity*, audience `https://graph.microsoft.com`.
4. `Parse JSON`, then `Filter array` where `status` equals `needsApproval` and `requestDateTime`

is newer than 15 minutes ago.

5 **For each** result, post an adaptive card to the approvers' Teams channel (or email a distribution list) with the request name, requester, justification, expiry and a link to **Tenant administration › Multi Admin Approval**.

GRANT THE LOGIC APP IDENTITY A READ-ONLY GRAPH APP ROLE — POWERSHELL

```powershell
Connect-MgGraph -Scopes 'AppRoleAssignment.ReadWrite.All','Application.Read.All'
$mi    = Get-MgServicePrincipal -Filter "displayName eq 'la-maa-notify'"          # Logic App identity
$graph = Get-MgServicePrincipal -Filter "appId eq '00000003-0000-0000-c000-000000000000'"
$role  = $graph.AppRoles | Where-Object Value -eq 'DeviceManagementRBAC.Read.All'  # confirm in Graph
docs
New-MgServicePrincipalAppRoleAssignment -ServicePrincipalId $mi.Id -PrincipalId $mi.Id `
  -ResourceId $graph.Id -AppRoleId $role.Id
```

Option 2 · Azure Monitor alert on Intune audit logs

In **Tenant administration › Diagnostic settings** send *AuditLogs* to a Log Analytics workspace, then create a scheduled query alert (every 15 minutes) with an action group that emails or posts to Teams. Create one test request first and inspect the rows to confirm the exact operation names in your tenant.

ALERT QUERY · NEW MAA ACTIVITY — KQL

```kql
IntuneAuditLogs
| where TimeGenerated > ago(15m)
| where OperationName has_any ("OperationApproval", "MultiAdminApproval")
| extend p = parse_json(Properties)
| project TimeGenerated, OperationName, Identity, ResultType, Target = tostring(p.TargetDisplayNames)
```

5.2 Method D · Audit the application-permission bypass

Because app-only identities are outside MAA, the matching compensating control is to know exactly which apps could wipe devices, who owns them and whether they still need the permission. Run this audit quarterly and attach the CSV to the access review record.

GET-INTUNEPRIVILEGEDAPPS.PS1 · COMPENSATING-CONTROL AUDIT — POWERSHELL

```powershell
[CmdletBinding()]
param(
  [string[]] $Permissions = @('DeviceManagementManagedDevices.PrivilegedOperations.All',
                              'DeviceManagementManagedDevices.ReadWrite.All'),
  [string]   $OutCsv      = ".\intune-privileged-apps-$(Get-Date -Format yyyyMMdd).csv"
)
$ErrorActionPreference = 'Stop'
Connect-MgGraph -NoWelcome -Scopes 'Application.Read.All'
$graph = Get-MgServicePrincipal -Filter "appId eq '00000003-0000-0000-c000-000000000000'"
$roles = $graph.AppRoles | Where-Object Value -in $Permissions
$grants = Get-MgServicePrincipalAppRoleAssignedTo -ServicePrincipalId $graph.Id -All |
          Where-Object AppRoleId -in $roles.Id
$rows = foreach ($g in $grants) {
  $sp  = Get-MgServicePrincipal -ServicePrincipalId $g.PrincipalId
  $app = Get-MgApplication -Filter "appId eq '$($sp.AppId)'"        # empty for multi-tenant apps
```

```
  $own = (Get-MgServicePrincipalOwner -ServicePrincipalId $sp.Id |
          ForEach-Object { $_.AdditionalProperties.userPrincipalName }) -join '; '
  $live = @($app.PasswordCredentials + $app.KeyCredentials | Where-Object EndDateTime -gt (Get-Date))
  [pscustomobject]@{
    Permission = ($roles | Where-Object Id -eq $g.AppRoleId).Value
    App = $sp.DisplayName; AppId = $sp.AppId; Type = $sp.ServicePrincipalType
    GrantedUtc = $g.CreatedDateTime; Owners = $own; ActiveCredentials = $live.Count
    HomeTenant = if ($app) { 'this tenant' } else { 'external / Microsoft' }
  }
}
$rows | Sort-Object Permission, App | Export-Csv $OutCsv -NoTypeInformation
$rows | Format-Table Permission, App, Owners, ActiveCredentials -AutoSize
if (-not $rows) { Write-Host 'No app holds the audited permissions.' -ForegroundColor Green }
```

For each row decide: remove the grant, rotate to certificate credentials with short lifetimes, restrict sign-in with Conditional Access for workload identities (named locations), and alert on any new consent to these permissions in the Entra audit log.

CHAPTER 6

Verification, Evidence and Troubleshooting

6.1 Verification tests

Test	Expected result
Wipe a test device as an initiator	Dialog reads *Request for wipe*; nothing is sent to the device.
Initiator opens their own request	`Approve` is unavailable.
Approver (member, group role-assigned) approves	Status *Approved*; initiator can now `Complete`.
Initiator completes	Device wipes; status *Completed*.
Retire and delete on test devices	Also produce requests (Step 5 done).
Notification flow	Approver channel receives the request within 15 minutes.
Audit log	Request, approval and completion recorded with initiator, approver, justification and times.

6.2 Rollback

Deleting or editing an access policy is itself an approval request, so rollback also needs two administrators. To relax the control temporarily (for example during a mass device-retirement project) submit a change to remove the relevant policy type, get it approved and completed, and re-create it at the end of the window under the same change record.

6.3 Framework mapping

MAA *supports* these objectives; it does not satisfy them alone. Full coverage also needs the retire/delete policies, the notification flow, the bypass audit and periodic reviews. Validate against your own baseline before citing in an assessment.

Framework	Control	How MAA contributes
NIST SP 800-53 Rev 5	AC-3(2) Dual Authorization	A destructive device action executes only after a second administrator approves.
	AC-5 Separation of Duties	Request and approval are separated; initiators cannot approve their own requests.

	AC-6, AC-6(9) Least Privilege; Log Use of Privileged Functions	Scoped initiator/approver roles; each privileged request is logged.
	CM-5 Access Restrictions for Change; AU-2, AU-12	Dual authorization on a high-impact change; requests and approvals generate audit records.
NIST CSF 2.0	PR.AA-05; GV.RR-02; DE.CM	Least privilege and separation of duties; defined authorities; monitored approval queue.
ISO/IEC 27001:2022	A.5.3 Segregation of duties; A.8.2 Privileged access rights; A.8.15 Logging	Four-eyes principle for wipes; constrained privileged actions; logged workflow.
CIS Controls v8	6.8 Role-based access control; 8.2, 8.5 Audit logs	Role-scoped access and collected audit events. CIS v8 has no dedicated two-person safeguard.

In regulated life-sciences environments the same request-and-approval trail supports data-integrity expectations such as 21 CFR Part 11 §11.10(d) and (e) and ALCOA+ principles. MAA governs administrative actions only; it is not an electronic-records system and does not by itself establish Part 11 compliance.

Evidence for assessment

- ☐ This SOP with its approval record; the three access policy configurations and approver group.
- ☐ Approver group membership and the Intune role assignment that authorizes it.
- ☐ MAA request records from the Intune audit log (initiator, approver, justification, timestamps).
- ☐ Quarterly approver-membership review and Method D app audit outputs.

6.4 Troubleshooting

Symptom	Likely cause and fix
Approver sees no requests / cannot approve	Approver group not assigned to an Intune role, or the user is an owner rather than a member.
Approver group cannot be selected or fails silently	Group is a Microsoft 365, distribution or mail-enabled group. Recreate as a security group.
Wipe still executes immediately	Policy not yet completed (Step 4), or wrong policy type. Check Access policies status.
Retire or delete not gated	Only the wipe policy exists. Complete Step 5.

Requests expire unnoticed	No notification flow, or the flow's identity lost its permission. Test Method C.
Graph call returns 400 on policy creation	Beta enum changed (`policyType` / `policyPlatform`). Read a portal-created policy and align values.
Devices wiped without a request in the log	Action came from an app-only identity or a local reset. Investigate with Method D and Entra sign-in logs for service principals.

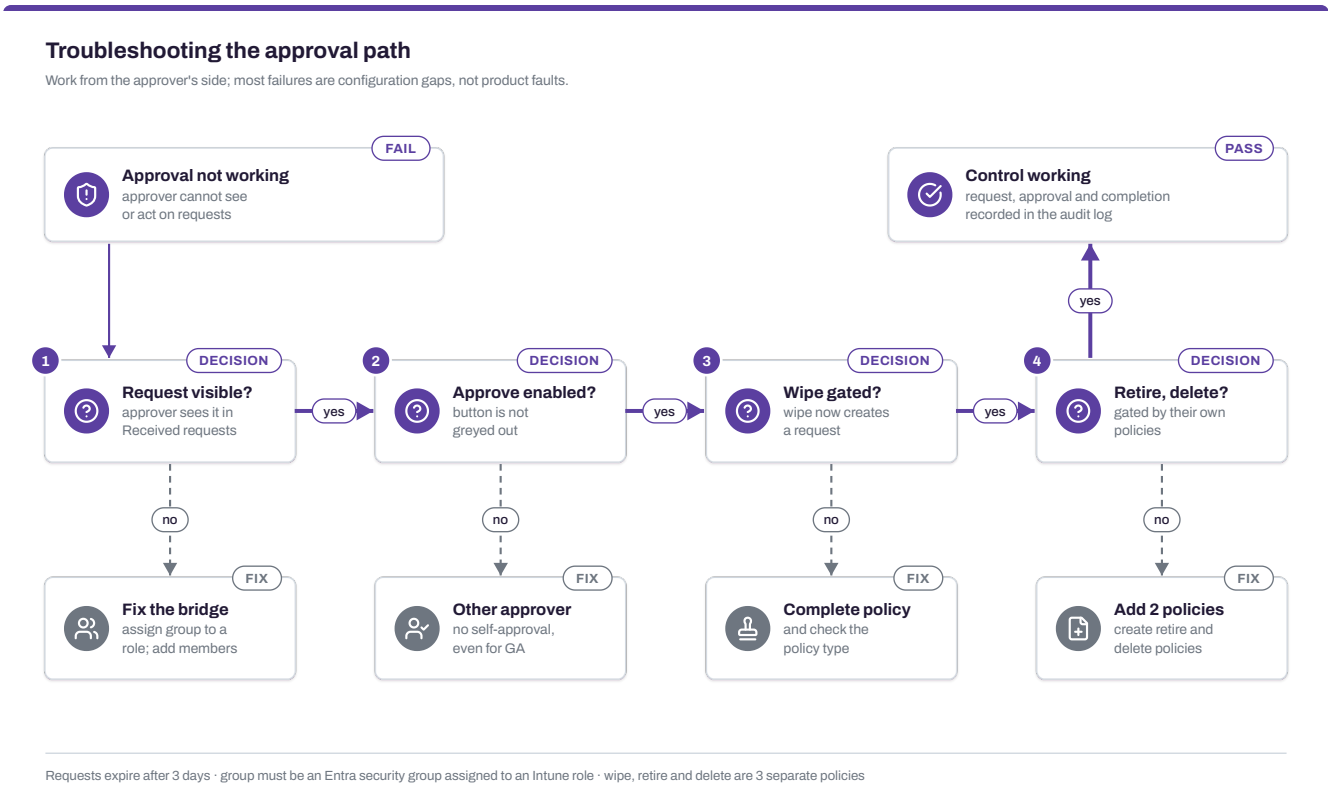


Figure 12. Most approval-path failures are configuration gaps (the bridge role assignment, an uncompleted policy, a missing policy type) rather than product faults.

CHAPTER 7

Summary, Glossary and Review

7.1 Chapter summary

- MAA enforces a two-person rule: one initiator, one different approver, then completion by the initiator.
- Approvers work only when their security group is assigned to an Intune role; wipe, retire and delete each need their own policy.
- App-only identities bypass MAA; audit them and alert on new privileged consents. Intune does not notify approvers; build a flow.
- MAA supports NIST AC-3(2) and AC-5, ISO A.5.3 and CIS 6.8 when paired with these compensating controls.

Check your understanding

1. Why can't a Global Administrator approve their own wipe request?
2. Which configuration step most often makes approvals fail silently, and why?
3. An automation account wiped 40 devices without any MAA request. How was this possible, and which control should have caught it?
4. Why should the notification Logic App hold only read permissions?
5. Which three policy types are required to close the destructive-action path?

7.2 Glossary

Four-eyes principle	Two different people must take part in a sensitive action.
Separation of duties	Splitting a task so no single person can complete it alone.
Access policy	MAA object naming a protected action type and its approver group.
Initiator / approver	The admin who requests and completes an action / the different admin who authorizes it.
Application permission	Graph permission used by an app with no signed-in user; outside MAA.
Wipe / retire / delete	Factory reset / remove company data and management / remove the device record.